Control Frameworks

- ISO/IEC 27001: International Standard
- NIST (SP 800-53): Required for US government use
- COBIT: Focused on business values
- ISA/IEC 62443 (ISA 99): Industrial Automation and Control Systems

© 2018 Al-Nafi. All Rights Reserved.

These frameworks will be covered in detail in later courses taught within Cyber, Offensive, DFIRM, IT Audit, SCADA and other tracks inshAllah.

Tailoring Security Controls



© 2018 Al-Nafi. All Rights Reserved.

Control frameworks and standards are intended to be tailored to specific use-cases. By nature, the control frameworks are general cases that are intended to be widely applied. For that reason, they may lack specifics on implementation details or require the control user to input specific values for their organization or environment (e.g., control says you have to have a screen lock but allows the adopter to select a lock timeout that makes sense for their use). It is critical to adjust control specifications or parameters to meet the needs of a specific system or environment to provide the optimal security value. The tailoring process is well documented in most control frameworks and fully supported by the frameworks themselves. Some organizations choose to treat controls and control frameworks as checklists and forego intelligent tailoring, thus, reducing the overall security value of the controls.

Evaluation Criteria



© 2018 Al-Nafi. All Rights Reserved.

Each control should include specific evaluation methods and expected results. To be effective as a security control, the control must be valuable and have one or more measures of effectiveness associated with it.

The NIST framework defines three primary methods of control evaluation:
Test: Conduct a direct test of the control (usually used for technical type controls)
Interview: Interview or question staff (usually used for management or operational controls)
Examine: Examine documentation or artifacts for evidence that a control is properly employed (used for all control types). In many cases, a control may (and should) be evaluated using multiple evaluation methods to ensure control effectiveness. For instance, to evaluate a particular control, the assessor may perform a technical test to validate a function, examine documentation to ensure the function was correctly configured, and interview a system administrator regarding operation of the function. Taken together, the results may show that the control is effectively applied or that there is some deficiency that limits the control effectiveness.

System Security Capabilities

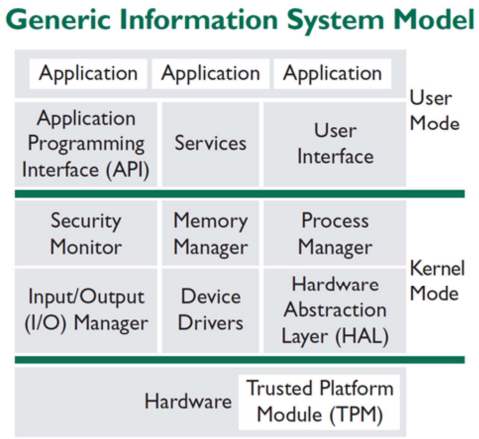


© 2018 Al-Nafi. All Rights Reserved.

Variations of these common capabilities are integrated into most modern operating systems and hardware platforms. The specific methods and types of implementation will vary from platform to platform but all typically share some of the common security value obtained from these capabilities.

System security capabilities generally interact with one or more other security capabilities or have some level of integration with other security components. This provides an integrated defense-in-depth model within the system architecture itself to limit the overall attack surface of the system and harden it against different forms of attack. However, security capabilities may be disabled or not fully integrated based on particular vendor products chosen as system components, or technical implementation by the system manufacturer or operator. For maximum functionality, integrated system security capabilities must typically be enabled and properly configured to provide desired protective capabilities.

Generic Operating System (OS)/Computer Model



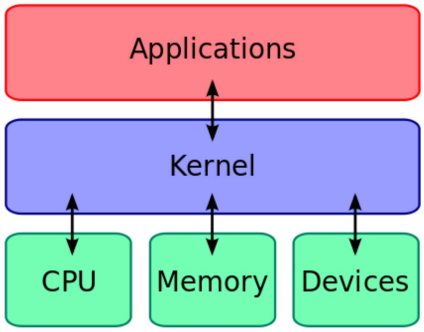
© 2018 Al-Nafi. All Rights Reserved.

In the above generic representation of an operating system. It does not represent a particular operating system, but it contains elements common to most modern operating systems. This diagram can be used for reference when considering the system security capabilities described in the following sections.

In a modern operating system, there are two primary processor states:
a user mode and a kernel mode. The kernel mode is reserved for core operating system management while the user mode is exposed to user applications and services. Functions allowed to execute on the hardware are limited in user mode and managed by processes that exist in kernel mode. This provides a level of abstraction that restricts actions that can be taken at the user level. There is an additional layer of separation in many operating systems call the Hardware Abstraction Layer (HAL) that acts as an interface between some user and kernel mode operations and the actual system hardware. This allows for standardized commands directed at hardware to be generalized and
translated to device specific commands but also limits the binary command set that can be sent directly to hardware components. Device drivers function in a similar fashion but may allow more direct control over specific hardware devices based on

manufacturer specifications. The hardware layer may include specialized security hardware such as a Trusted Platform Module (TPM).

What is system kernel?



© 2018 Al-Nafi. All Rights Reserved.

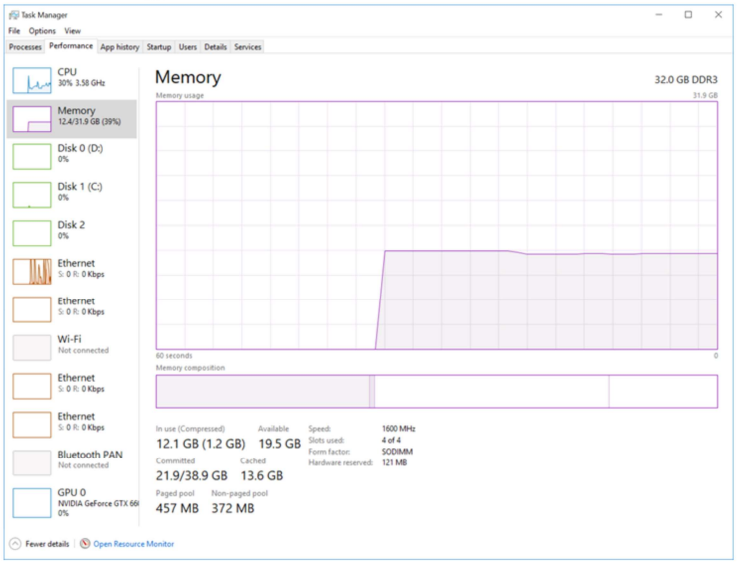
The system kernel is the core of an OS, and one of its main functions is to provide access to system resources, which includes the system's hardware and processes.

The kernel:

- Loads and runs binary programs
- Schedules the task swapping that allows computer systems to do more than one thing at a time
- Allocates memory
- Tracks the physical location of files on the computer's hard disks.

The kernel provides these services by acting as an interface between other programs operating under its control and the physical hardware of the computer; this insulates programs running on the system from the complexities of the computer.

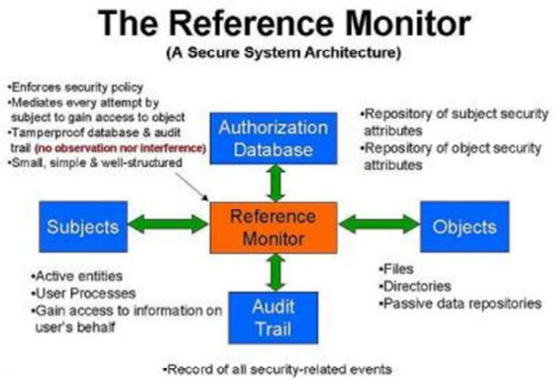
Memory Manager



© 2018 Al-Nafi. All Rights Reserved.

Allocates and manages physical and/or virtual memory within a system.

Reference Monitor or Security Monitor

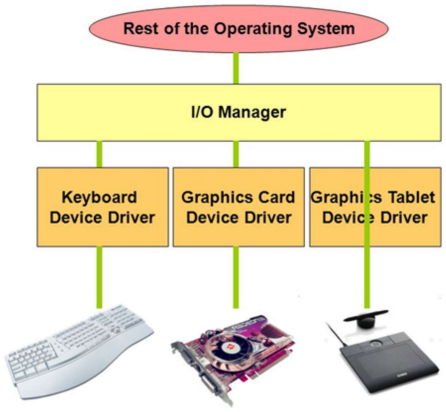


© 2018 Al-Nafi. All Rights Reserved.

Enforces access control policy and rules over subjects interacting with objects and performing operations. It is typically intended to be always on and impossible to bypass for any function. It operates in kernel mode and provides oversight to the operation of internal OS functions.

Input/Output (I/O) Manager

Input/Output Management



Provides a way of controlling hardware devices connected to the computer

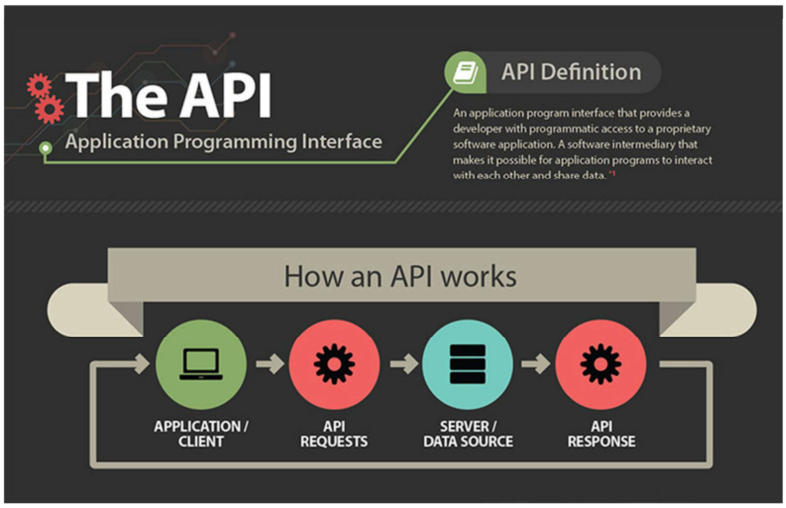
Adding a new device means a new driver has to be installed before it will work

© 2018 Al-Nafi. All Rights Reserved.

9

Manages and controls input and output from the operating system.

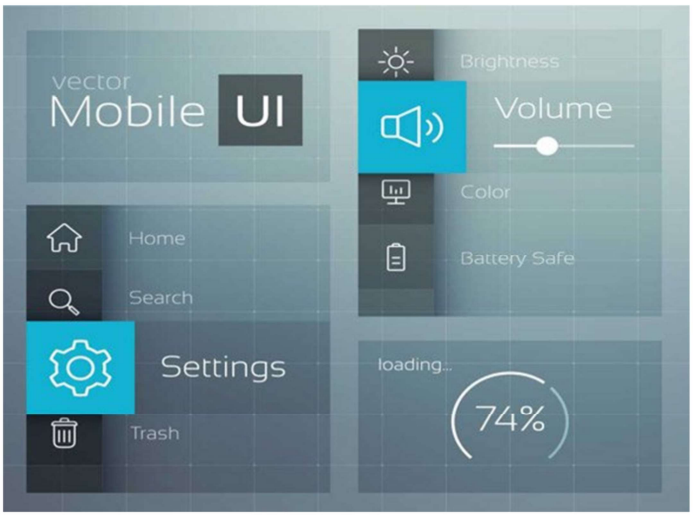
Application Programming Interface (API)



© 2018 Al-Nafi. All Rights Reserved.

Provides a generalized or common set of commands for applications or processes executing on a system to perform standard operations and communications. It removes the need for applications to directly interface with some OS components and hardware.

User Interface



© 2018 Al-Nafi. All Rights Reserved.

The UI presents control and input methods to system users in an understandable and controlled fashion. It often includes common user interaction functions that can be easily implemented by applications or code executing on the system.